

TECHNICAL EVALUATION REPORT

ADVANCED THREAT DETECTION & API SECURITY HARDENING (WEEK 4)

Intern Name	Muhammad Saim Ali Khan	ID / Reference	DHID-4044
Assigned Role	Cyber Security Analyst	Evaluation Date	May 27, 2026
Platform Track	Node.js / Express Architecture	Testing Client	Postman API Environment

1. Executive Summary

During the Week 4 implementation cycle, the development team successfully targeted critical perimeter vulnerabilities and operational blind spots within the Node.js core backend infrastructure. The core objective focused on applying strict compliance controls across application-layer routing, network header exchange layers, and dynamic brute-force mitigation fields.

All milestone objectives were completely satisfied. Security layers were built natively into the application middleware stack to manage stateless token evaluation, global and localized endpoint rate throttling, custom perimeter cross-origin request policies, and real-time structured intrusion auditing logs. Technical alignment and operational compliance have been rigorously validated via programmatic execution traces and end-to-end sandbox assertions in Postman.

2. Intrusion Detection & Log Auditing Architecture

To satisfy real-time anomaly tracking vectors, a dedicated security logging lifecycle was integrated utilizing the winston telemetry framework. The system actively captures atomic metadata profiles for every authentication lifecycle event, parsing parameters into a structured, append-only file ledger (`security.log`).

Consecutive Failure Mitigation Logic

The backend handles brute-force scenarios by tracking localized authentication failures in memory. When unauthenticated clients supply incorrect credential inputs, the runtime updates a localized sequence state tracker. Upon hitting a threshold boundary of exactly **three (3) consecutive failed attempts**, the runtime automatically overrides normal handling to throw an accelerated security warning.

```
logger.warn({
  message: "INTRUSION DETECTION ALERT: Multiple failed login attempts tracked.",
  attemptCount: failureTracker[username],
  clientIP: req.ip,
  timestamp: new Date().toISOString()
});
```

System Architecture Note: Firewall Escalation & Fail2Ban Alignment

The application is explicitly designed for seamless compliance with enterprise-grade system monitors like **Fail2Ban** or **OSSEC**. Because every telemetry entry maps tracking objects to a unified, predictable JSON syntax inside `security.log`, system administrators can configure regex jail filters on the host OS to automatically ingest this data stream and dynamically enforce iptables/firewall drop blocks at the network layer.

3. API Security Hardening & Gateways

Perimeter exposure vectors were mitigated through a multi-tiered middleware framework, addressing credential cracking, access escalation, and illegal resource harvesting.

3.1. Rate Limiting Implementation

Utilizing `express-rate-limit`, the system deploys a decoupled, defensive throttling model:

- **Global Request Limiter:** Established standard rate limiting across all generic discovery routes to block automated scrapers.
- **Stricter Login Gateway Limiter:** Hardened the `POST /login` resource specifically, limiting rapid programmatic submissions to insulate the Bcrypt computation thread from processor exhaustion.

3.2. Stateless JSON Web Tokens (JWT)

Authentication session logic was moved entirely away from stateful cookies into secure, cryptographic Bearer tokens signed via `jsonwebtoken`. Resource safety is handled strictly on inbound traffic via a localized custom gateway handler:

```
const authenticateToken = (req, res, next) => {
  const authHeader = req.headers['authorization'];
  const token = authHeader && authHeader.split(' ')[1];
  if (!token) return res.status(401).json({ error: "Access Denied: Missing token" });

  jwt.verify(token, JWT_SECRET, (err, user) => {
    if (err) return res.status(403).json({ error: "Access Denied: Invalid token",
    reason: err.message });
    req.user = user;
    next();
  });
};
```

3.3. Cross-Origin Resource Sharing (CORS) Restraints

To prevent unauthorized browser-based script access and cross-domain data leaking, explicit origin white-listing policies were enforced via custom `corsOptions` arrays, restricting operational access exclusively to authorized host endpoints.

4. Security Headers & CSP Implementation

Inbound security configuration parameters on the HTTP response envelope are handled using the `helmet` security middleware library, effectively closing typical client-side exploit vectors.

Header Control	Direct Security Purpose	Implementation Strategy
Content Security Policy (CSP)	Eliminates Cross-Site Scripting (XSS) and data injection execution vectors.	Explicitly locks <code>script-src</code> definitions to trusted local and execution-safe parameters.
Strict-Transport-Security	Enforces encrypted transport lanes across clients (HSTS Mitigation).	Injects a strict max-age policy directive on the browser envelope to force mandatory TLS/HTTPS execution.
X-Frame-Options	Protects against UI redress UI attacks (Clickjacking).	Configured to block iframe layout nesting on foreign or un-whitelisted external pages.

5. Technical Verification & Audit Records

Functional pipeline integrity has been successfully established across the sandbox testing cycle. Below is the structured mapping blueprint for adding the corresponding execution visual proofs directly within the final documentation file:

VISUAL RECORD 1: SUCCESSFUL USER AUTHENTICATION & TOKEN DELIVERY

Application Context: Postman execution profile hitting POST `http://localhost:3000/login`. Demonstrates receipt of credentials, error-free dynamic Bcrypt password verification, and the output generation of a 200 OK authenticated Bearer JWT payload.

VISUAL RECORD 2: PROTECTED ENDPOINT ACCESS VALIDATION

Application Context: Postman execution profile hitting GET `http://localhost:3000/list`. Demonstrates structural passing of the unquoted Bearer token explicitly inside the HTTP Authorization header to bypass the 403 route defense and capture the protected system data pack.

VISUAL RECORD 3: LIVE APPLICATION RUNTIME AUDIT TRAIL

Application Context: VS Code developer terminal interface. Captures real-time output streams from execution milestones: server instantiation, dynamic password-hash generation on-boot, inbound payload logging parameters, and the manual cryptographic token validation confirmation hooks.

VISUAL RECORD 4: STRUCTURED SECURITY LOG APPEND VERIFICATION

Application Context: VS Code workspace document viewer parsing security.log. Proves real-time JSON format telemetry handling by Winston, saving persistent logs of authorization steps, failed attempts, and active intrusion telemetry strings.

6. Summary of Fulfilled Deliverables

The code updates completed meet 100% of the technical deliverables outline specified in the core week syllabus requirements:

Syllabus Deliverable Item	Execution Status	Core Validation Metric
Secured API with Rate-Limiting Controls	COMPLETED	Dual-layer global & route limiters verified operational via client simulation.
Implemented Enterprise Security Headers	COMPLETED	Helmet modules dynamically injecting active CSP and HSTS instructions.
Real-time Intrusion Monitoring Hook	COMPLETED	Persistent JSON logging streams formatted perfectly for Fail2Ban/OSSEC ingestion.
GitHub Repository & Documentation	READY TO PUSH	Code streamlined with robust engineering features and descriptive comments pruned.

[END OF COMPLIANCE SECURITY FINDINGS REPORT — DOCUMENT CONTROLS LOCKED]